

4月30日域渗透作业

- 1、前置配置
 - 1.1、配置burp环境并添加证书
 - 1.2、打开CTF的pikachu靶场
 - 1.3、启动BurpSuite
 - 2、表单暴力破解复现
 - 2.1、准备密码本
 - 2.2、开始暴力破解
 - 3、pikachu靶场中验证码绕过（on server）
 - 3.1、准备密码本
 - 3.2、开始暴力破解
- 总结：

1、前置配置

1.1、配置burp环境并添加证书

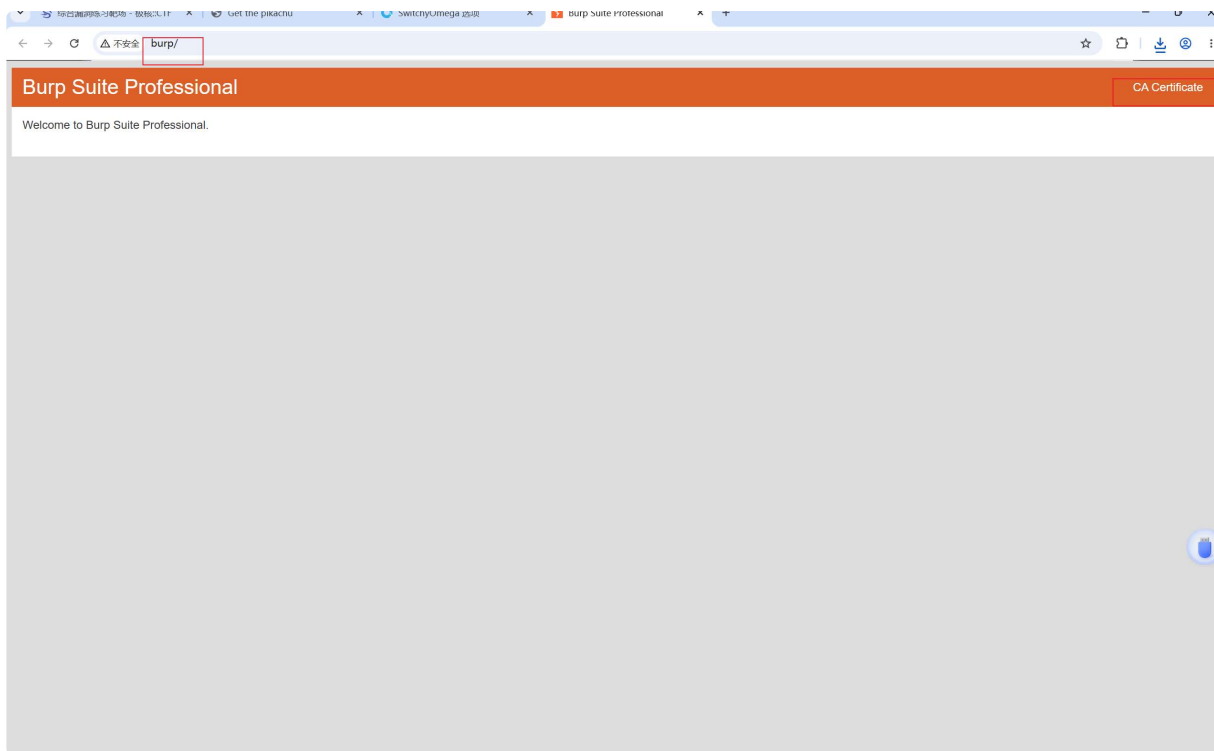
先将chrome的SwitchyOmega插件增加情景模式burp，配置如下：



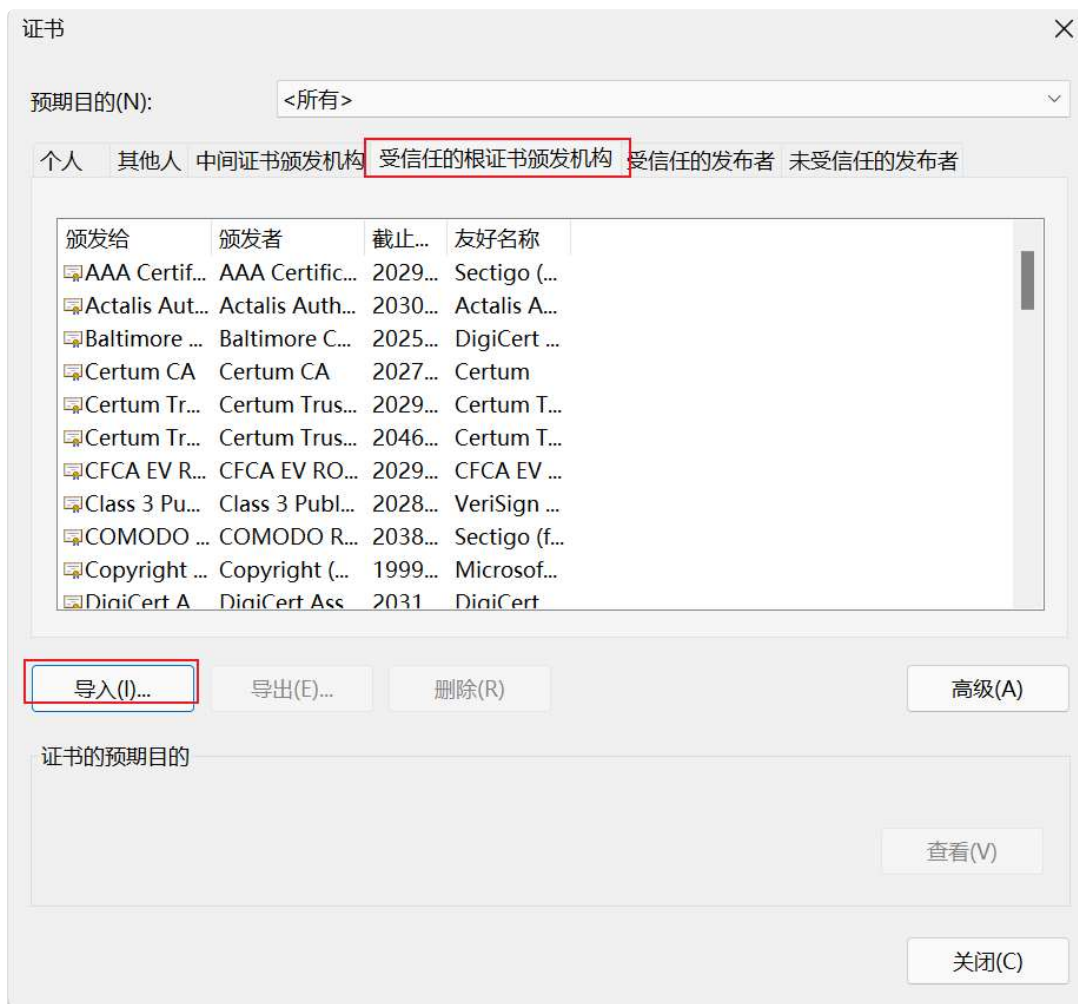
然后将SwitchyOmega设置为burp



进入burp/网站，并下载证书



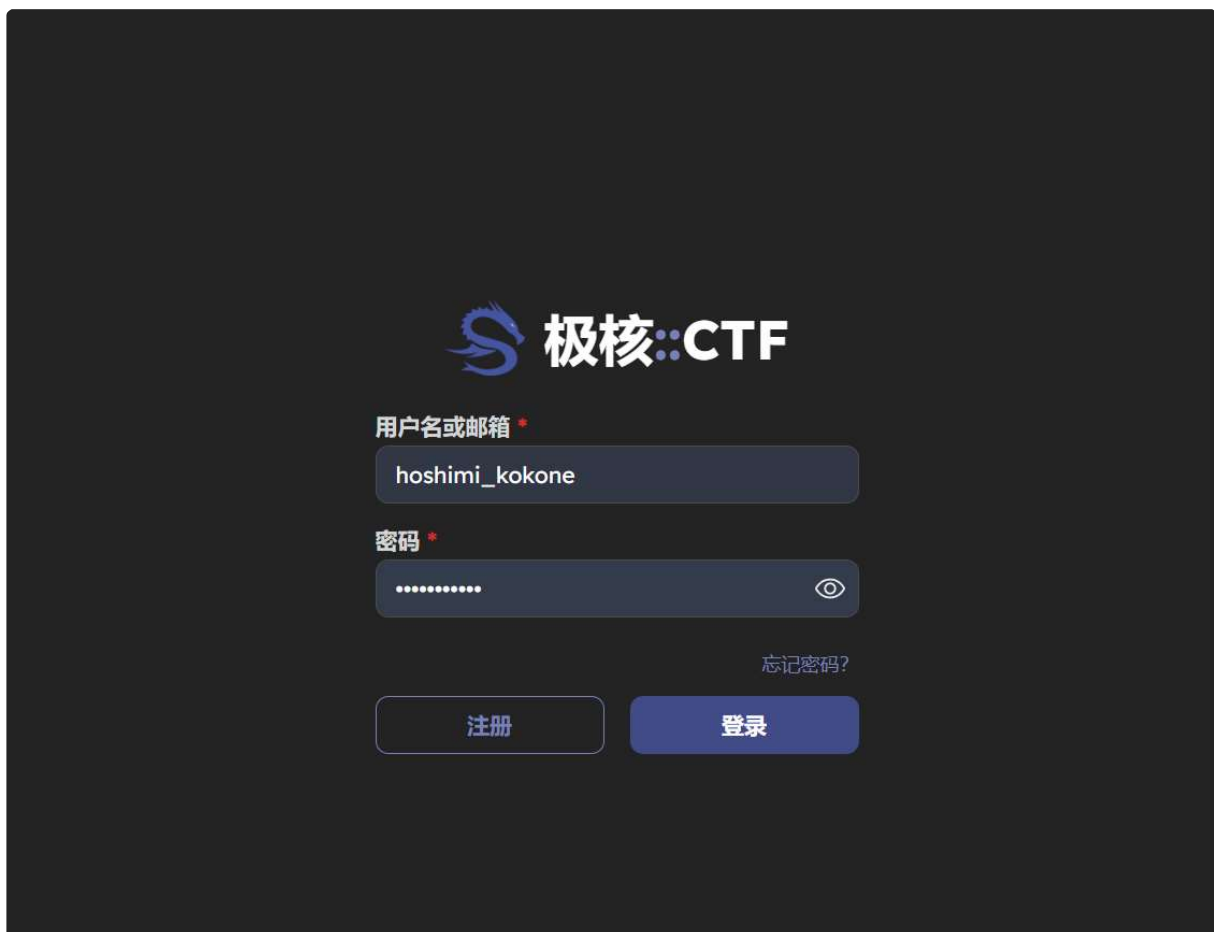
然后把下载的证书添加到chrome的受信任的根证书颁发机构的证书



导入完毕后即添加完毕证书

1.2、打开CTF的pikachu靶场

打开CTF网站 (<https://hackhub.get-shell.com/>) 并登录



没有队伍，创建队伍



参加综合漏洞练习靶场的比赛并进入比赛

团队赛

综合漏洞练习靶场

2883支队伍已报名

开始时间
2024年4月13日凌晨12点00分

结束时间
2040年12月31日凌晨12点00分

审核通过

查看榜单

进入比赛



简介

包含多种开源的漏洞靶场，如Pikachu、DVWA、Sqli-Labs等多种开源漏洞靶场，主要目的是为了帮助用户可以对主流漏洞类型进行系统性的学习，了解主流漏洞类型的原理与利用方法。

注意事项

- 禁止在靶机内进行容器逃逸、利用靶机对互联网进行非法扫描等其他会对极核GetShell官方以及互联网造成危害的行为！
- 如违规并造成实际影响的，将依法进行相应的移送机关处理！
- 好好珍惜朋友们，免费的才是最贵的，莫凉了他人心。

想说的话

选择pikachu比赛

综合漏洞练习靶场

比赛还会很久

比赛题目

隐藏已解出

All 9

Web 9

AspGoat

10 pts

50 次解出

DVWA

10 pts

323 次解出

JavaSecLab

10 pts

85 次解出

Mimikyu

10 pts

196 次解出

Pikachu

10 pts

320 次解出

Sqli-Labs

10 pts

248 次解出

Upload-Labs

10 pts

161 次解出

Xss-Labs

10 pts

184 次解出

bWAPP

10 pts

125 次解出

目标成为galgan

2883 总排名

0 得分

全部 通知 动态

25/10/28 19:09:42

恭喜 武汉战队 获得 [AspGoat]

25/10/27 20:37:20

恭喜 戴剑 获得 [AspGoat]

25/10/24 09:57:51

恭喜 苏城猎手 获得 [AspGoat]

25/10/24 09:56:33

题目 [AspGoat] 已开放

25/04/22 11:06:18

题目 [JavaSecLab] 已开放

25/03/24 18:45:43

恭喜 天极 获得 [JavaSecLab]

25/03/22 19:39:13

恭喜 ytx 获得 [JavaSecLab]

25/03/21 15:15:07

恭喜 苏城猎手 获得 [JavaSecLab]

创建实例，然后打开链接网址

https://www.yuque.com/xinyun-prb75/god851/lf3129q75qotrzc4/pdf#print

5/17

 **Pikachu** 10 pts

- **靶机类型:** 综合漏洞练习
- **启动说明:** 创建实例后请耐心等待, 直到靶机完全启动
- **Flag获取:**
 - 签到Flag位于靶机首页
 - 注意: Flag 仅为练习的一部分, 探索更多漏洞才是最终目标
- **源码来源:** Pikachu

本题为容器题目, 解题需开启容器实例
容器默认有效期为 60 分钟

已经尝试提交 0 次

人生得意须尽欢, 莫使 fLag 空对月

创建实例 **提交 flag**

 **Pikachu** 10 pts

- **靶机类型:** 综合漏洞练习
- **启动说明:** 创建实例后请耐心等待, 直到靶机完全启动
- **Flag获取:**
 - 签到Flag位于靶机首页
 - 注意: Flag 仅为练习的一部分, 探索更多漏洞才是最终目标
- **源码来源:** Pikachu

实例入口 作为网页打开

 node.hackhub.get-shell.com:62003  

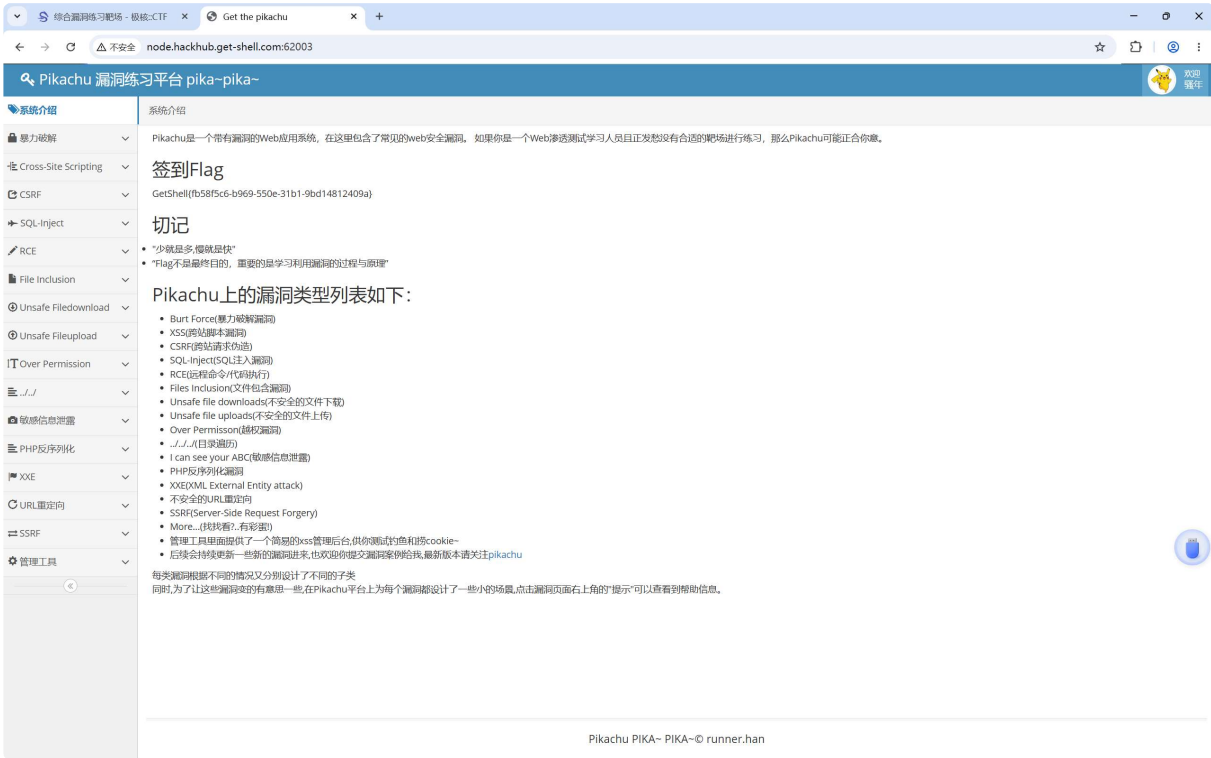
剩余时间: 00:59:52
你可以在到期前 30 分钟内延长时间

延长时间 **销毁实例**

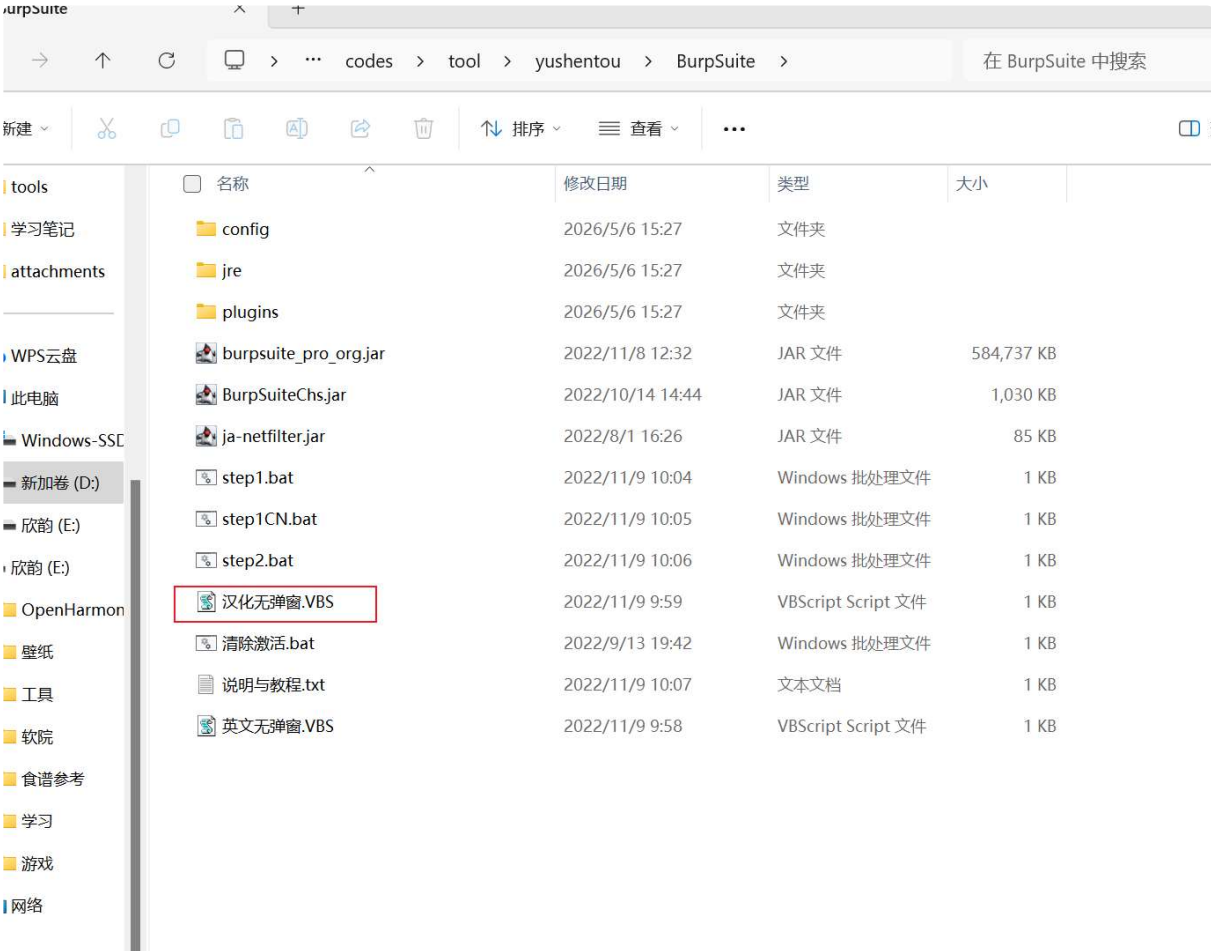
已经尝试提交 0 次

flag 当关, 万夫莫开 **提交 flag**

进入网站后即可开始实验



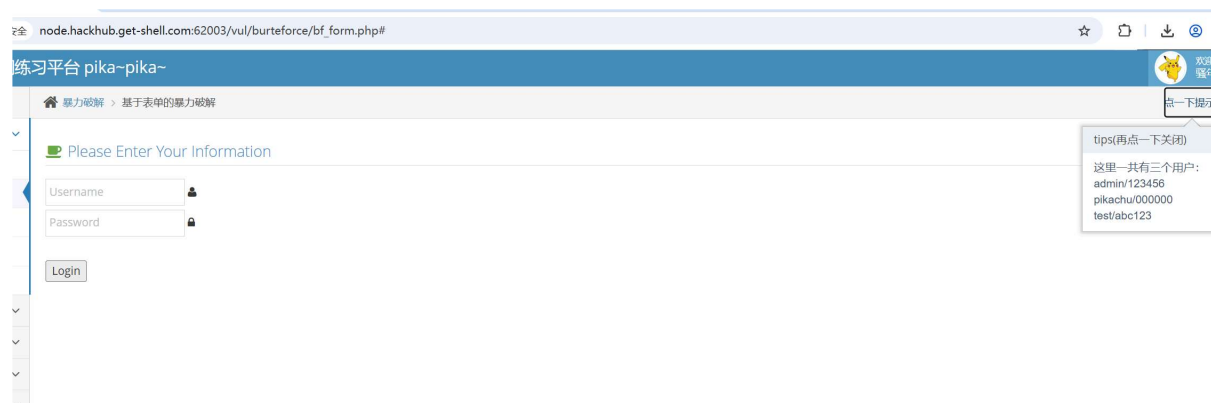
1.3、启动BurpSuite



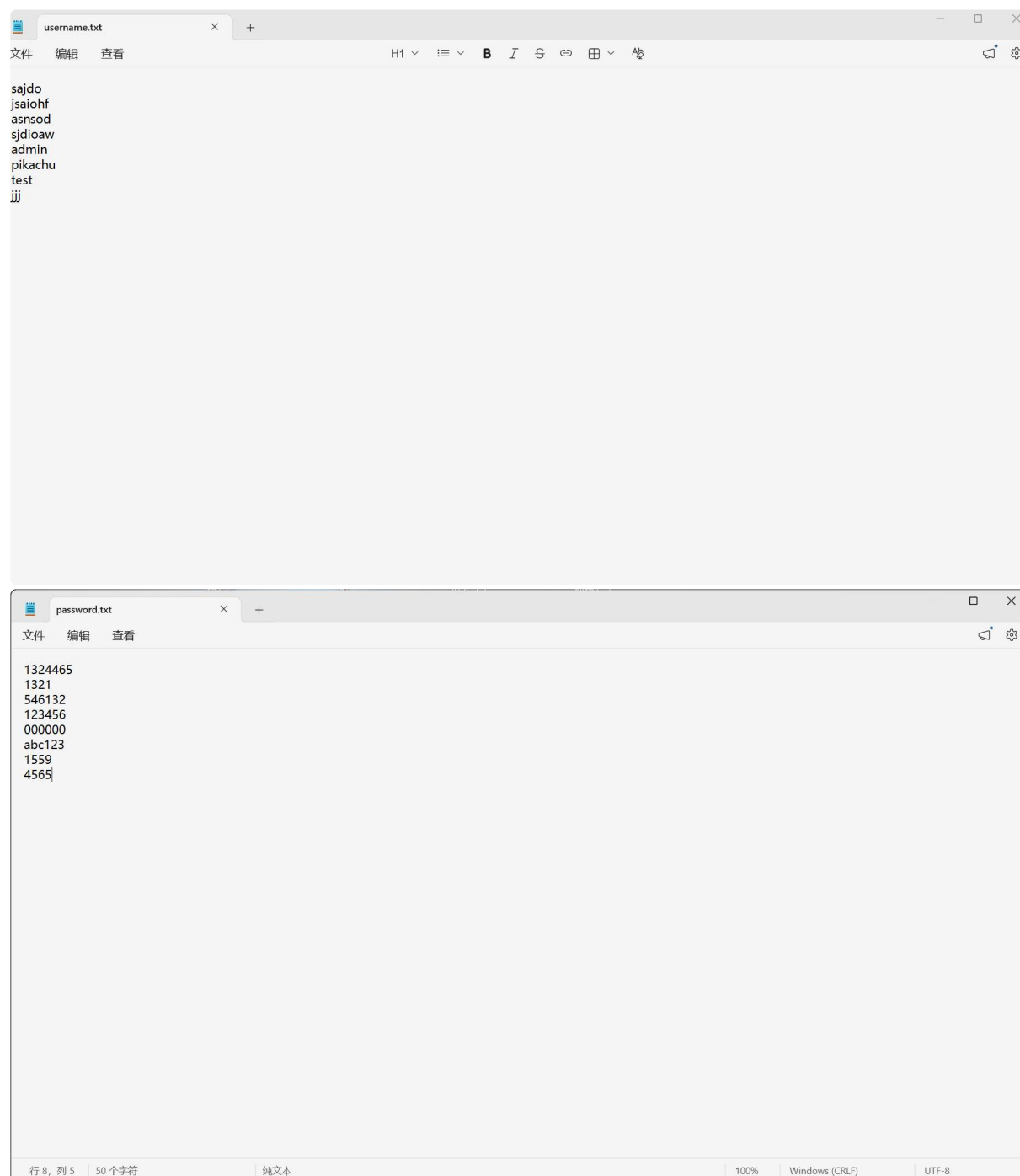
2、表单暴力破解复现

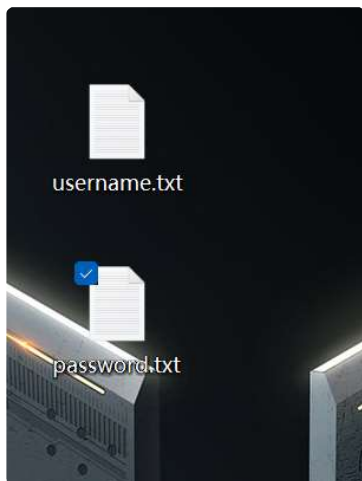
2.1、准备密码本

查看pikachu基于表单的暴力破解的正确账号和密码



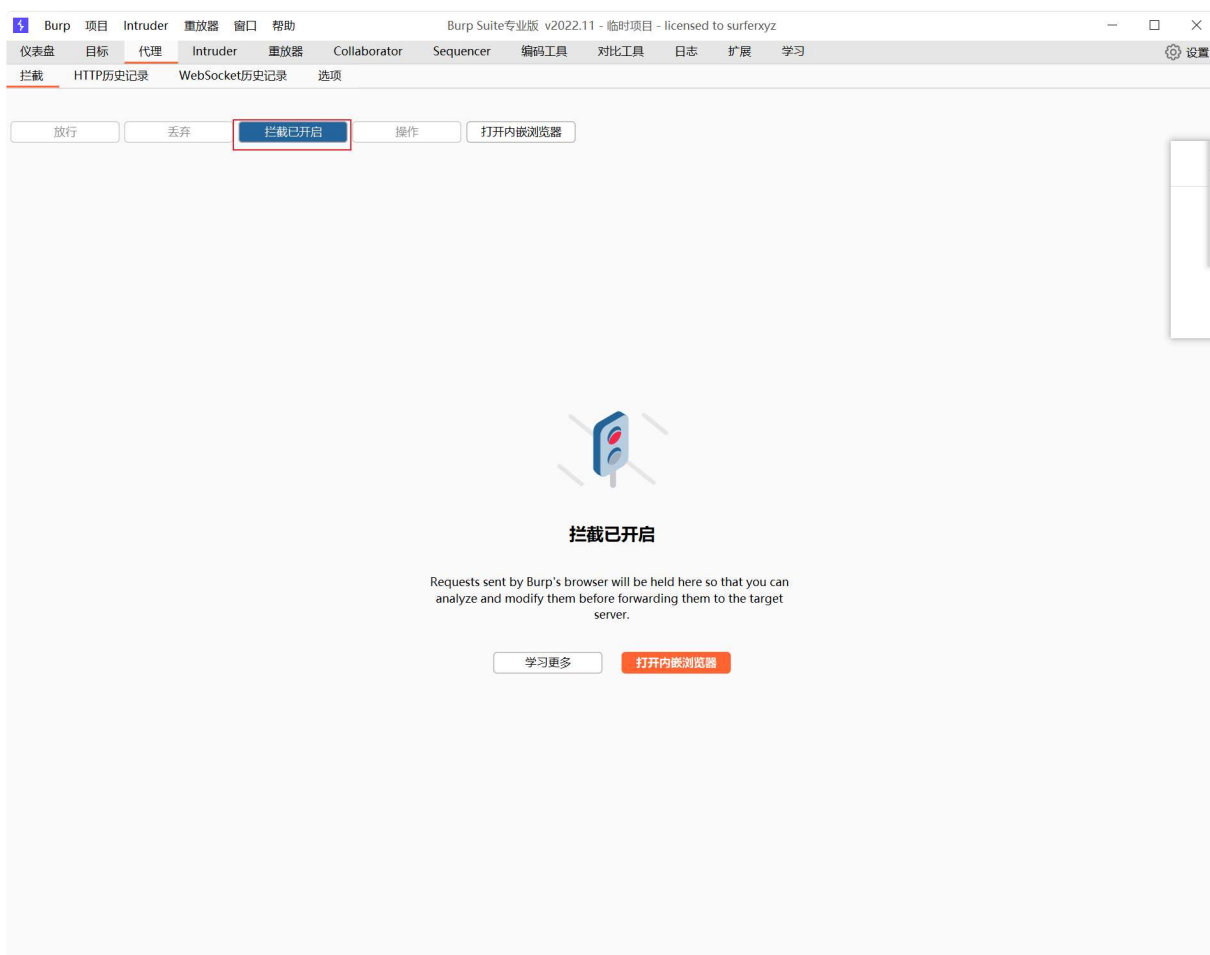
准备username和password的密码本





2.2、开始暴力破解

开启代理拦截



产生登录请求

暴力破解 > 基于表单的暴力破解

Please Enter Your Information

wang'jia'xin

.....

Login

username or password is not exists ~

在拦截HTTP历史记录中，找到发送username和password的数据包，右键，将它添加进Intruder

#	Host	请求方法	URL	参数
61	http://node.hackhub.get-shell.com	POST	/vul/burteforce/bf_form.php	✓

添加到范围

扫描

被动扫描

主动扫描

发送到Intruder Ctrl+I

发送到Repeater Ctrl+R

发送到Sequencer

发送到Comparer

通过浏览器请求 >

相关工具(Engagement tools) >

显示新的历史窗口

添加注释

高亮 >

删除条目

清空历史

复制网址

以curl格式复制

保存条目

代理历史记录帮助文档

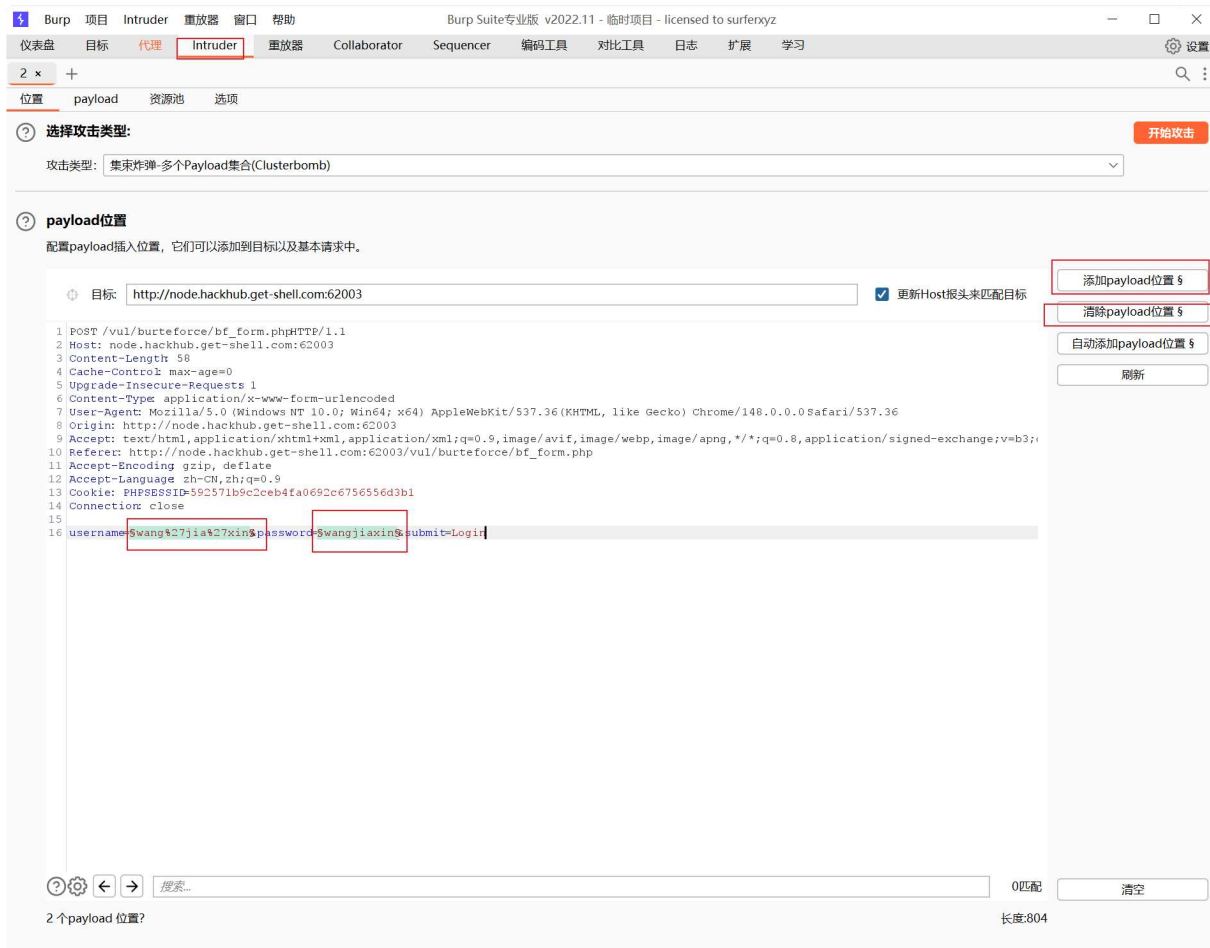
请求

美化 Raw Hex

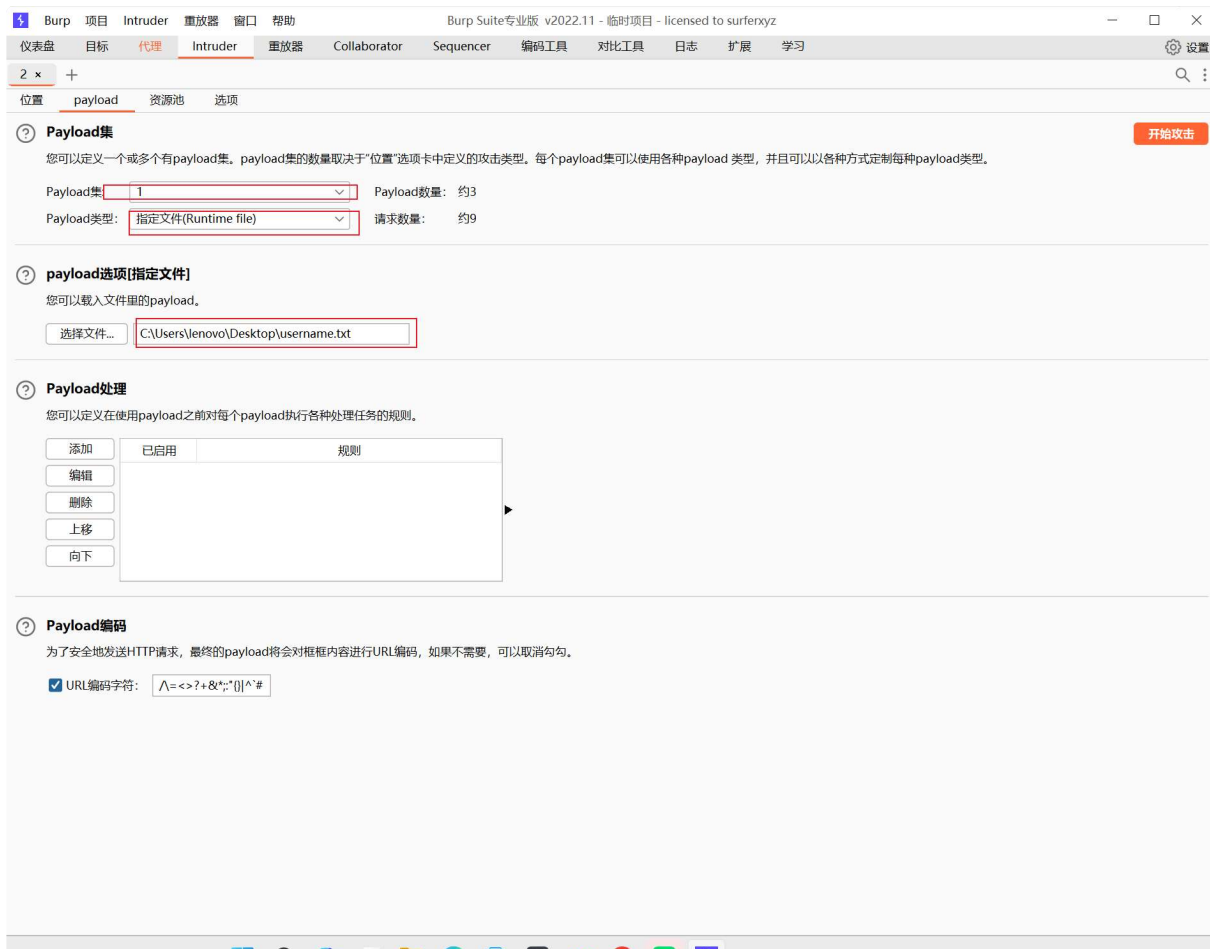
```

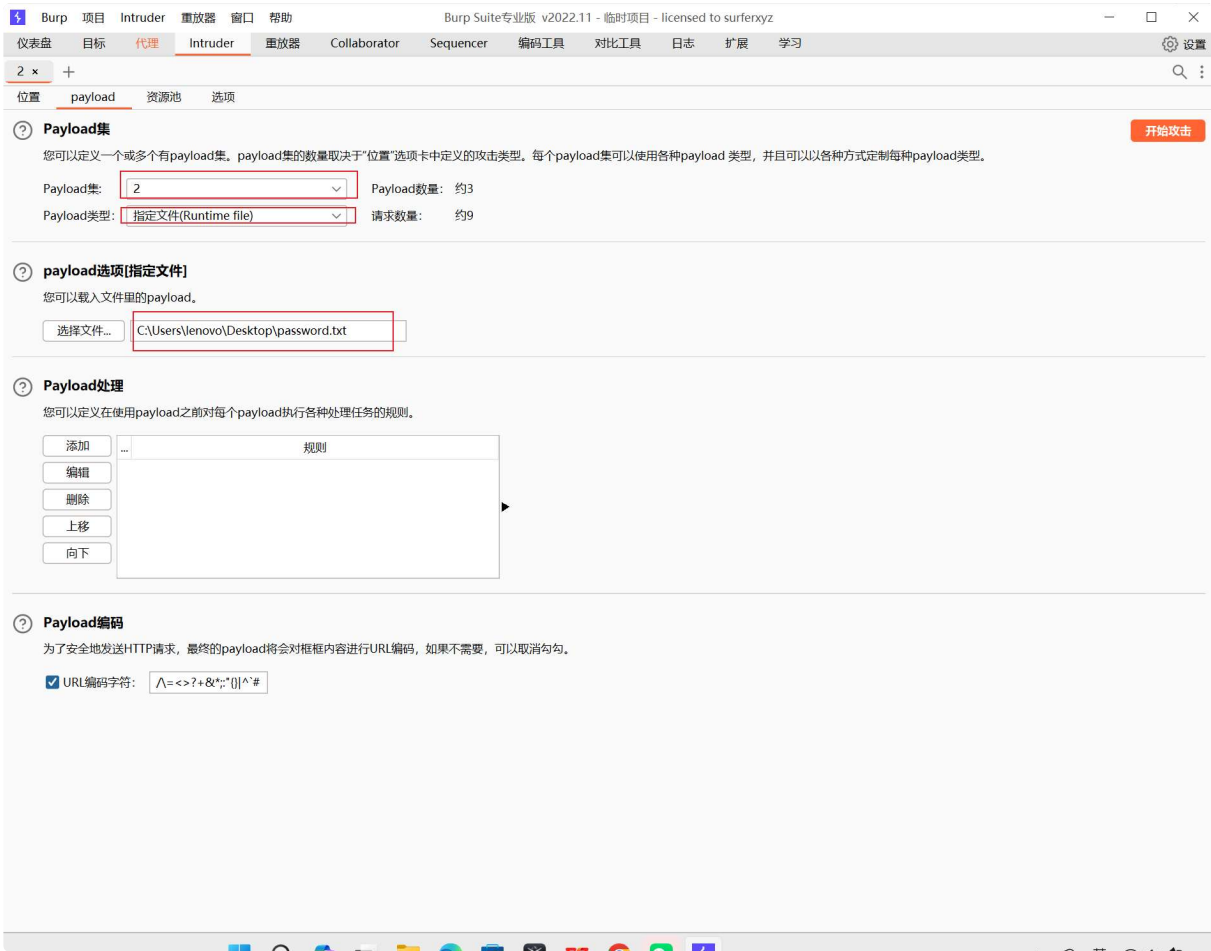
1 POST /vul/burteforce/bf_form.php
2 Host: node.hackhub.get-shell.com
3 Content-Length: 58
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Content-Type: application/x-www-form-urlencoded
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/104.0.0.0 Safari/537.36
8 Origin: http://node.hackhub.get-shell.com:62003
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.7
10 Referer: http://node.hackhub.get-shell.com:62003/vul/burteforce/bf_form.php
11 Accept-Encoding: gzip, deflate
12 Accept-Language: zh-CN,zh;q=0.9
13 Cookie: PHPSESSID=592571b9c2ceb4fa0692c6756556d3b1
14 Connection: close
15
16 username=wang%27jia%27xin&password=wangjiaxin&submit=Login
  
```

进入Intruder页面，然后选择集束炸弹攻击类型，清除payload位置，然后再username和password位置扎入payload位置



进入payload页面, 分别设置payload集1和payload集2的密码本, 然后开始攻击





攻击后，找到长度不同的记录，他们的username和password即为正确username和password

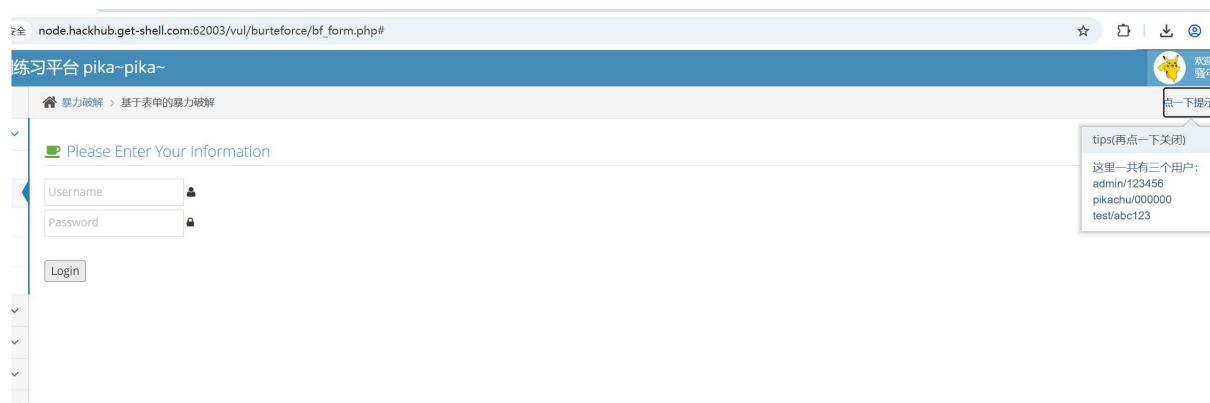
20	sjdioaw	546132	200	☐	☐	35014
21	admin	546132	200	☐	☐	35014
22	pikachu	546132	200	☐	☐	35014
23	test	546132	200	☐	☐	35014
24	jjj	546132	200	☐	☐	35014
25	sajdo	123456	200	☐	☐	35014
26	jsaiohf	123456	200	☐	☐	35014
27	asnsod	123456	200	☐	☐	35014
28	sjdioaw	123456	200	☐	☐	35014
29	admin	123456	200	☐	☐	34990
30	pikachu	123456	200	☐	☐	35014
31	test	123456	200	☐	☐	35014
32	jjj	123456	200	☐	☐	35014
33	sajdo	000000	200	☐	☐	35014
34	jsaiohf	000000	200	☐	☐	35014
35	asnsod	000000	200	☐	☐	35014
36	sjdioaw	000000	200	☐	☐	35014
37	admin	000000	200	☐	☐	35014
38	pikachu	000000	200	☐	☐	34990
39	test	000000	200	☐	☐	35014
40	jjj	000000	200	☐	☐	35014
41	sajdo	abc123	200	☐	☐	35014
42	jsaiohf	abc123	200	☐	☐	35014
43	asnsod	abc123	200	☐	☐	35014
44	sjdioaw	abc123	200	☐	☐	35014
45	admin	abc123	200	☐	☐	35014
46	pikachu	abc123	200	☐	☐	35014
47	test	abc123	200	☐	☐	34990
48	iii	abc123	200	☐	☐	35014

基于表单的暴力破解完毕

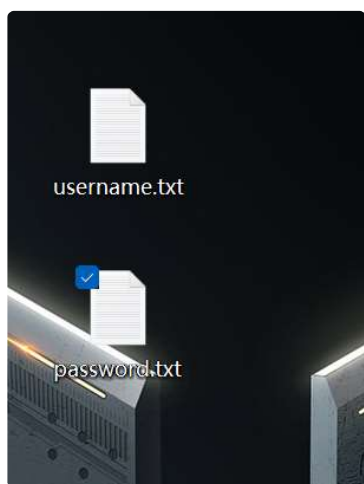
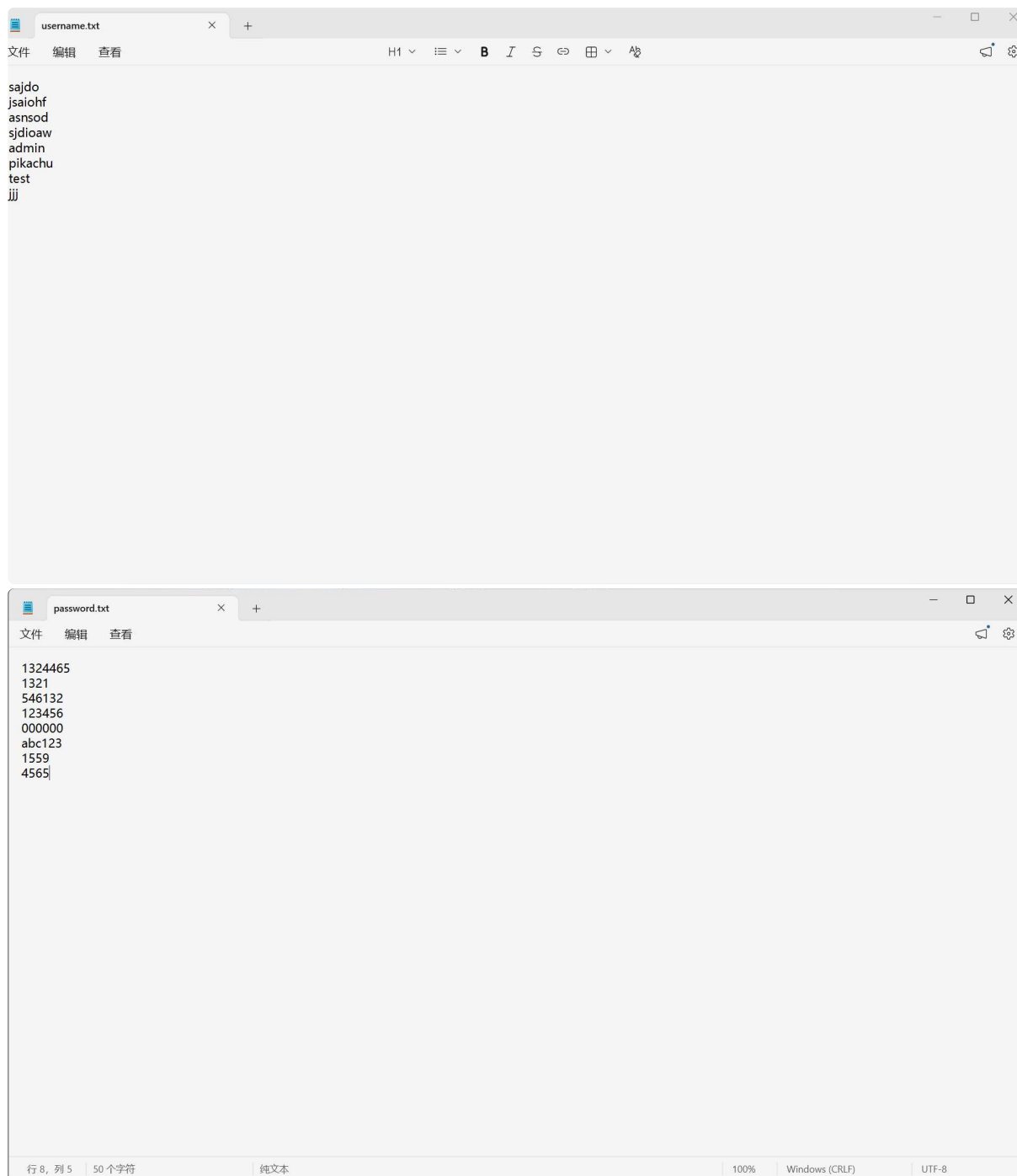
3、pikachu靶场中验证码绕过 (on server)

3.1、准备密码本

查看pikachu基于表单的暴力破解的正确账号和密码



准备username和password的密码本



3.2、开始暴力破解

发起登录请求

Please Enter Your Information

wangjiaxin

.....

ejkuoy

Login

进行暴力破解得到正确的username和password，然后找到发送登录信息的数据包，添加到Repeater里

拦截 HTTP历史记录 WebSocket历史记录 选项

过滤: 隐藏CSS, 图片, 一般二进制文件

#	Host	请求方法	URL	参数	已编辑	状态	长度	MIME类型	扩展	标题	注释
10	http://node.hackhub.get-shell.c...	GET	/vul/burteforce/bf_server.php			200	35230	HTML	php	Get the pikachu	
11	http://node.hackhub.get-shell.c...	POST	/vul/burteforce/bf_server.php					HTML	php		
12	https://support.google.com	GET	/ch	http://node.hackhub.get-shell.c...							
13	https://content-autofill.googlea...	GET	/v1	添加到范围							
14	https://www.googleapis.com	POST	/aff								
15	https://content-autofill.googlea...	GET	/v1	扫描							
16	https://content-autofill.googlea...	GET	/v1	被动扫描							
17	https://content-autofill.googlea...	GET	/v1	主动扫描							
18	https://android.clients.google.co...	POST	/c2	发送到Intruder	Ctrl+I						
19	https://accounts.google.com	POST	/dc	发送到Repeater	Ctrl+R						
20	https://google.com	POST	/dc	发送到Sequencer							

请求

美化 Raw Hex

1 POST /vul/burteforce/bf_server.phpHTTP/1.1

2 Host: node.hackhub.get-shell.com:46150

3 Content-Length: 65

4 Cache-Control: max-age=0

5 Upgrade-Insecure-Requests: 1

6 Content-Type: application/x-www-form-urlencoded

7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win

8 Origin: http://node.hackhub.get-shell.com:4

9 Accept: text/html,application/xhtml+xml,application

10 v=b3;q=0.7

11 Referer: http://node.hackhub.get-shell.com:

12 Accept-Encoding: gzip, deflate

13 Accept-Language: zh-CN,zh;q=0.9

14 Cookie: PHPSESSID=69e88ebd83dcfc9397efff7488b1e9e4

15 Connection: close

16 username=wangjiaxin&password=wangjiaxin&vcode=ejkuoy&submit=Login

Inspector

请求属性 2

请求体参数 4

请求Cookies 1

请求头 13

点击重放器，然后点击发送、页面渲染，然后修改正确的username，password，点击发送，直到login成功

1 Burp Suite 专业版 v2022.11 - 临时项目 - licensed to surferxyz

仪表盘 目标 代理 Intruder 重放器 Sequencer 编码器 对比工具 日志 扩展 学习

1 x +

发送 取消

目标: http://node.hackhub.get-shell.com:46150 HTTP/1

请求 美化 Raw Hex

```
1 POST /vul/burteforce/bf_server.php HTTP/1.1
2 Host: node.hackhub.get-shell.com:46150
3 Content-Length: 65
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Content-Type: application/x-www-form-urlencoded
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0
9 Safari/537.36
10 Origin: http://node.hackhub.get-shell.com:46150
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Referer: http://node.hackhub.get-shell.com:46150/vul/burteforce/bf_server.php
13 Accept-Encoding: gzip, deflate
14 Accept-Language: zh-CN,zh;q=0.9
15 Cookie: PHPSESSID=69e88ebd83dcfc9397efff7488ble9e4
16 Connection: close
17 username=wangjiaxin&password=wangjiaxin&vcode=gllpgv&submit=Login
```

响应 美化 Raw Hex 页面渲染

Pikachu 漏洞练习平台 pika-pika-

暴力破解 > 验证码绕过(on server) 点一下提示-

Please Enter Your Information

Username Password 验证码

Login

验证码输入错误哦!

Inspector

请求属性 2

请求查询参数 0

请求体参数 4

请求Cookies 1

请求头 13

响应头 9

完成 35,279字节 | 65毫秒

1 Burp Suite 专业版 v2022.11 - 临时项目 - licensed to surferxyz

仪表盘 目标 代理 Intruder 重放器 Sequencer 编码器 对比工具 日志 扩展 学习

3 x +

发送 取消

目标: http://node.hackhub.get-shell.com:46150 HTTP/1

请求 美化 Raw Hex

```
1 POST /vul/burteforce/bf_server.php HTTP/1.1
2 Host: node.hackhub.get-shell.com:46150
3 Content-Length: 56
4 Cache-Control: max-age=0
5 Upgrade-Insecure-Requests: 1
6 Content-Type: application/x-www-form-urlencoded
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
8 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0
9 Safari/537.36
10 Origin: http://node.hackhub.get-shell.com:46150
11 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
12 Referer: http://node.hackhub.get-shell.com:46150/vul/burteforce/bf_server.php
13 Accept-Encoding: gzip, deflate
14 Accept-Language: zh-CN,zh;q=0.9
15 Cookie: PHPSESSID=69e88ebd83dcfc9397efff7488ble9e4
16 Connection: close
17 username=admin&password=123456&vcode=wh3mtdt&submit=Login
```

响应 美化 Raw Hex 页面渲染

Pikachu 漏洞练习平台 pika-pika-

暴力破解 > 验证码绕过(on server) 点一下提示-

Please Enter Your Information

Username Password 验证码

Login

login success

Inspector

请求属性 2

请求查询参数 0

请求体参数 4

请求Cookies 1

请求头 13

响应头 9

完成 35,251字节 | 52毫秒

总结:

on server的验证码是在服务器端进行验证的所以在爆破的过程中验证码必须始终保持正确的。